КРАТКИЙ ИТОГ НА ОДНОЙ СТРАНИЦЕ

Постквантовая проверка криптографии: sigstore-js @ 769a53d87132

Клиент: Sigstore project — публичный репозиторий (пассивная проверка) · Код: github.com/sigstore/sigstore-js, коммит 769a53d87132 · Проверено: 2026-10-28 18:30 UTC · Профиль риска: Разработчик ПО безопасности

ПОСТКВАНТОВАЯ ЗРЕЛОСТЬ
Уровень 0 из 4
постквантовой криптографии нет

НАХОДКИ
1 Критическая **10** Высокая
11 Средняя **4** Низкая
2 Информационная

КВАНТОВЫЙ СРОК (МОСКА: X + Y − Z)
Подписи: 5 + 3 − 8 = 0 → **впритык**

Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

ГЛАВНОЕ

Критическая QSI-2026-05978	**proxy-addr 2.0.7 затронут GHSA-jqcg-44mw-7w3h (CVE-2026-90711)** Что сделать: Обновите до исправленной версии (2.0.8).
Высокая QSI-2026-05957	**Закрытый ключ присутствует в packages/cli/src/signer.ts** Что сделать: Считайте ключ скомпрометированным: замените его, отзовите связанные сертификаты, удалите из истории версий, храните ключи в менеджере...
Высокая QSI-2026-05955	**Срок действия сертификата истёк ((empty))** Что сделать: Перевыпустите сертификат и автоматизируйте продление (например, ACME) с мониторингом сроков.
Высокая QSI-2026-05961	**brace-expansion 5.0.9 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)** Что сделать: Обновите до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).

Ещё 22 — в полном отчёте.

ЧТО ЗАЩИЩАЕТ КВАНТОВО-УЯЗВИМАЯ КРИПТОГРАФИЯ

Роль	Алгоритмы	Что сделать
Низкая роль не определена	ECDSA	Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA...

ИЗВЕСТНЫЕ УЯЗВИМЫЕ ВЕРСИИ КОМПОНЕНТОВ

Бюллетеней для используемых версий: 21; каждый нужно сверить с кодом.

Статический анализ исходного кода и манифестов; проанализировано файлов: 180. Запросы к системам владельца не отправлялись.

Полный отчёт, SHA-256 содержимого: `dc5dfd0611af59e5724beaee5a3151159457f67dc81deebe8ed4ff09b683b1cb`

Подпись полного отчёта (report.sig.json): ключ Ed25519, отпечаток SHA-256 `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json содержит SHA-256 каждого файла комплекта и тоже подписан; verify-bundle проверяет его без сети.

Предварительные находки требуют подтверждения в коде; доказательства, границы каждой проверки и порядок повторной проверки — в полном отчёте.